

Politique de gestion des accès et des identités (IAM)

1. Objectif

Définir les règles, processus et contrôles permettant de gérer de manière sécurisée les identités numériques et les accès à la plateforme de gestion des auto-écoles et examens, afin de garantir la confidentialité, l'intégrité, la disponibilité et la traçabilité des données.

2. Périmètre

Cette politique s'applique à : - Tous les utilisateurs (candidats, moniteurs, responsables d'auto-écoles, examinateurs, agents administratifs) - Administrateurs de la plateforme - Équipe support et maintenance - Composants IA et services automatisés - API et intégrations tierces

3. Principes directeurs

- Principe du moindre privilège
- Séparation des rôles et des responsabilités
- Accès basé sur les rôles (RBAC) et, si nécessaire, sur les attributs (ABAC)
- Traçabilité complète des accès
- Révocation rapide des accès
- Authentification forte

4. Types d'identités

4.1 Utilisateurs humains

- Candidats
- Moniteurs
- Responsables d'auto-écoles
- Examineurs officiels
- Agents administratifs
- Administrateurs système

4.2 Identités techniques

- Comptes de service
- Comptes API
- Agents IA
- Scripts automatisés

5. Rôles et permissions (RBAC)

5.1 Rôles standards

- Candidat : consultation de dossier, inscription, paiement, suivi

- Moniteur : gestion des élèves, planning, suivi pédagogique
- Responsable auto-école : gestion établissement, moniteurs, finances, rapports
- Examineur : accès aux listes d'examen, résultats
- Agent administratif : validation, supervision, reporting
- Administrateur : gestion globale, configuration, sécurité

5.2 Matrice d'accès

Une matrice détaillée doit être maintenue séparément, listant chaque fonctionnalité et les rôles autorisés.

6. Authentification

6.1 Méthodes

- Mot de passe fort
- Authentification multi-facteurs (MFA) pour rôles sensibles
- Authentification par OTP (SMS, email, application)
- OAuth2 / OpenID Connect pour intégrations

6.2 Exigences mot de passe

- Longueur minimale
- Complexité
- Rotation périodique
- Interdiction de réutilisation

7. Gestion du cycle de vie des identités

7.1 Création

- Validation de l'identité
- Attribution du rôle initial
- Journalisation

7.2 Modification

- Validation hiérarchique
- Traçabilité des changements

7.3 Désactivation / suppression

- Désactivation immédiate en cas de départ
- Suppression après période de rétention

8. Gestion des accès privilégiés (PAM)

- Comptes administrateurs séparés
- Accès temporaire avec expiration
- Journalisation renforcée
- Revue périodique des accès privilégiés

9. Accès des systèmes IA

- Comptes techniques dédiés
- Accès strictement limités
- Journalisation complète
- Isolation logique des modèles et données

10. Journalisation et audit

- Journalisation des connexions
- Journalisation des échecs d'authentification
- Journalisation des changements de rôles
- Conservation des logs selon politique de rétention

11. Revue périodique des accès

- Revue trimestrielle minimale
- Validation par responsables métier
- Rapport d'écarts

12. Gestion des incidents IAM

- Détection d'accès non autorisés
- Suspension immédiate
- Enquête
- Notification selon obligations légales

13. Conformité et références normatives

Cette politique est alignée sur les bonnes pratiques suivantes : - ISO/IEC 27001 & 27002 - NIST SP 800-53 - NIST SP 800-63 (Digital Identity) - OWASP ASVS - Principes RGPD (minimisation, sécurité, traçabilité)

14. Responsabilités

- RSSI / Responsable sécurité
- Administrateurs système
- Responsables métiers
- Direction de la plateforme

15. Mise à jour

Cette politique doit être revue au minimum une fois par an ou après tout changement majeur de l'architecture ou des obligations réglementaires.